AI PROMPT INJECTION: LAYERED DEFENSE IN ACTION

Multiple, independent controls work together so a single bypass does not lead to compromise.

USER / EXTERNAL INPUT

Please summarize Q2 financial results and prepare a payment of $250,000 to Vendor ABC.

ATTACKER GOAL

Use prompt injection to make the model ignore instructions and initiate an unauthorized financial transfer.

LAYERED DEFENSE PIPELINE

1 INPUT CLASSIFIER
Detect Injection Attempts

Analyzes the input for signs of prompt injection, jailbreaks, and policy violations.

Checks include:
- Injection patterns
- Role override attempts
- Instruction hijacking
- Obfuscation / encoding

PASS No injection detected

FAIL Request blocked and logged

2 SEMANTIC VALIDATION
Intent Consistency Check

Compares the intent of the model's output to the intent of the original request.

Validates:
- Intent alignment
- Scope adherence
- Policy compliance
- Entity / action consistency

PASS Intent aligned

FAIL Output blocked and logged

3 OUTPUT MONITORING
Behavioral Consistency

Monitors the generated output for anomalies and behaviors inconsistent with expected patterns.

Monitors for:
- Sensitive data exposure
- Unexpected tool / action calls
- Policy or safety violations
- High-risk content or tone

PASS Output safe

FAIL Response blocked and logged

4 STRICT SCOPING
Limit Capabilities & Blast Radius

The model operates with the minimum necessary tools, data, and permissions.

Scope enforcement:
- Least-privilege tool access
- No direct system / API access
- Data access limited to scope
- Action templates & allowlists

PASS Within allowed scope

EVEN IF INJECTION SUCCEEDS Damage is contained by strict scope and guardrails.

5 HUMAN-IN-THE-LOOP
High-Risk Action Checkpoint

High-risk actions require explicit human approval before execution.

Triggers include:
- Financial transactions above threshold
- Data deletion / changes
- Privilege modifications
- External communications
- Production changes

AWAITING HUMAN APPROVAL Approve / Reject

OUTCOME

ACTION EXECUTED SAFELY
All layers passed and human approval obtained (if required). Action executed within policy and scope.

ACTION BLOCKED
Blocked by one or more layers. Incident logged for review and continuous learning.

CENTRALIZED SECURITY LOGGING & OBSERVABILITY
All requests, decisions, reasons for blocking, and approvals are logged to an immutable audit store for monitoring, alerting, and forensics.

HOW THE LAYERED DEFENSE WORKS

1. Input is analyzed for injection attempts. If detected, it is blocked.
2. If input passes, the system checks that the model's output matches the intent of the original request.
3. Output is monitored for anomalies and safety or policy violations.
4. Even if earlier layers are bypassed, strict scoping limits what the model can access or do.
5. If the action is high-risk, human approval is required before execution.

→ Safe & compliant outcome.

DEFENSE-IN-DEPTH PRINCIPLES

- Multiple independent controls
- Fail closed: block on uncertainty
- Least privilege and least capability
- Human oversight for high risk
- Continuous monitoring and improvement

LEGEND

- Normal Flow
- Blocked Flow
- Passed
- Blocked
- Control / Guardrail